PS 1 — AI FOR ELECTORAL ROLL TRANSPARENCY

ElectraLens

Technical Architecture & Build Checklist

> *Public data, public methodology, public evidence, private identities.*

Founder	Aryan Yadav
Version	0.1 — draft for approval
Date	27 October 2026
Build window	24-hour hackathon, production-grade foundations
Checklist	219 items in 21 modules, traced to every requirement
Companion	ElectraLens-PRD.pdf (requirements, architecture, threat model, roadmap)

Contents

1. Technology stack
2. Runtime topology
3. Repository layout
4. Shared conventions
5. Database design (Supabase Postgres)
6. Build checklist — foundations and core engine
7. Build checklist — data, API and integrity
8. Build checklist — public experience
9. Build checklist — accounts, operations console and governance
10. Build checklist — privacy and security (cross-cutting)
11. Build checklist — deployment and operations · S8 · hours 17–20
12. Build checklist — testing and quality gates
13. Build checklist — demo, pitch and video · S9 · hours 20–24
14. Traceability: every requirement → checklist items
15. Still open before or at hour 0

ElectraLens is an independent project. It is not affiliated with, endorsed by, or acting for the Election Commission of India. All demo data is synthetic.

ElectraLens — Technical Architecture and Build Checklist

Version 0.1 · 2026-10-27 · Builds on **01-PRD.md**, **02-ARCHITECTURE.md**, **03-THREAT-MODEL.md** and **04-ROADMAP.md**.

This is the working document for the 24-hour build. Every feature in the PRD has at least one checklist item here. §14 maps each requirement, user story, acceptance criterion and threat to the items that deliver it, so nothing gets missed.

How to use the checklist

- Item IDs look like `B04.03` (B = build, module 04, item 03). They're stable, so commits and PRs can refer to them. Threat IDs (`T01` – `T25`) are from the threat model.
- Tick `[x]` only when the item is built **and** its test passes.
- **P0** items are committed. **P1** items are stretch goals and are dropped in the order of the roadmap cut list. **P2** items are for the pilot and are listed so nothing is forgotten.
- Hour ranges refer to the 24-hour schedule in the roadmap.

---

1. Technology stack

These are the current releases from npm and PyPI, checked on 2026-10-27. Lockfiles pin exact versions at S0.

Layer	Choice	Version	Why
JS runtime	Node.js LTS	24.x	Already installed. One runtime for web, api and anchor.
Package manager	pnpm workspaces	12.x	Monorepo with strict dependency isolation
Web	Next.js (App Router) + React	16.4 / 19.3	Server rendering and incremental revalidation for fast public pages
Styling	Tailwind CSS	4.3	Fast to build, no runtime JS
Languages	next-intl	4.14	Locale routing, ICU messages for en / hi / third language
Charts	Our own server-rendered SVG components	—	Zero client JS on public pages (NFR-9), with a data table alongside every chart (NFR-7)
API	Fastify + fastify-type-provider-zod + @fastify/rate-limit	5.12 / 7.0 / 11.2	Fast, schema-first, built-in rate limiting
Validation	zod	4.6	Request and response schemas shared by web and api
Supabase client	@supabase/supabase-js + @supabase/ssr	2.118 / 0.12	Auth cookies in Next.js, per-request clients that respect RLS
Logging	pino with redaction	10.4	Structured logs without personal data (NFR-11)
JSON canonicalisation (TS)	canonicalize (RFC 8785)	5.1	Reference JCS implementation
QR codes	qrcode	1.5	SVG output
Chain client	ethers v6	6.17	Same library in the browser verifier and the anchor service
Contracts	Hardhat 3 + OpenZeppelin Contracts	3.21 / 5.6	TypeScript-native, works on Windows, audited `AccessControl`

Layer	Choice	Version	Why
Engine runtime	Python 3.12 managed by uv	uv 0.11	uv is installed and fetches 3.12. Same version as the Docker image.
Data and stats	Polars, NumPy, SciPy, RapidFuzz	2.1 / 2.4 / 1.17 / 3.14	Deterministic dataframes, statistics, fuzzy name matching
Engine models	pydantic	2.14	Typed models that mirror the JSON Schemas
Database driver	psycopg 3	3.3	Job queue with `SKIP LOCKED` through the session pooler
HTTP (Python)	httpx	0.28	Supabase Storage REST, alerts
JSON canonicalisation (Python)	rfc8785	0.1.4	Produces the same canonical bytes as the TS side
Timestamps	opentimestamps-client	0.7.2	Stamp, upgrade and verify OTS proofs
Tests	vitest 5, pytest 9, Hardhat tests, pgTAP (Supabase CLI), Playwright 1.64		
Lint	ESLint + TypeScript strict, ruff 0.17		
Database, auth, storage	Supabase free tier + Supabase CLI 2.122 (run through npx)		Local development in Docker
Chain network	Ethereum Hoodi testnet, chain ID 560048		Decision D5
Containers	Docker Compose	Docker 29	

2. Runtime topology

Service	Base image	Listens on	Exposed to host	Memory limit [P]	Secrets it holds
`web`	node:24-alpine, Next.js standalone build	3100	127.0.0.1:3100	384 MB	None. Only public values: anon key, Turnstile site key.
`api`	node:24-alpine	4100	127.0.0.1:4100	256 MB	Service-role key, Turnstile secret, anchor HMAC key, alert tokens, optional LLM key
`anchor`	node:24-alpine	4200	**Not exposed** (Docker network only)	192 MB	Publisher private key, anchor HMAC key, service-role key (MVP)
`worker`	python:3.12-slim	—	Not exposed	1 GB	Worker database URL, service-role key (for Storage)

That's about 1.8 GB of limits. Real use is usually lower, but the VPS size still needs checking (decision D10).

Environment variables (names only; values live in `.env.example` with no secrets and in Docker secret files on the VPS):

Scope	Variables
Shared	`APP_ORIGIN`, `SUPABASE_URL`, `SUPABASE_ANON_KEY`, `CHAIN_ID=560048`, `RPC_URL`, `REGISTRY_ADDRESS`, `REGISTRY_DEPLOY_BLOCK`
web (public)	`NEXT_PUBLIC_SUPABASE_URL`, `NEXT_PUBLIC_SUPABASE_ANON_KEY`, `NEXT_PUBLIC_TURNSTILE_SITE_KEY`, `NEXT_PUBLIC_RPC_URL`, `NEXT_PUBLIC_REGISTRY_ADDRESS`, `NEXT_PUBLIC_CHAIN_ID`, `API_INTERNAL_URL`
api	`SUPABASE_SERVICE_ROLE_KEY_FILE`, `TURNSTILE_SECRET_KEY_FILE`, `ANCHOR_URL=http://anchor:4200`, `ANCHOR_HMAC_KEY_FILE`, `LLM_PROVIDER=none|gemini|ollama`, `LLM_API_KEY_FILE`, `ALERT_TELEGRAM_BOT_TOKEN_FILE`, `ALERT_TELEGRAM_CHAT_ID`
anchor	`PUBLISHER_PRIVATE_KEY_FILE`, `ANCHOR_HMAC_KEY_FILE`, `SUPABASE_SERVICE_ROLE_KEY_FILE`, `CONFIRMATIONS=1`

Scope	Variables
worker	`DATABASE_URL_FILE` (Supavisor **session** pooler, IPv4), `SUPABASE_SERVICE_ROLE_KEY_FILE`, `WORKER_ID`, `POLL_INTERVAL_MS=3000`

Secrets use the `*_FILE` convention, so the value is read from `/run/secrets/...` and never sits in the environment of the wrong container.

3. Repository layout

```
electralens/
├─ package.json · pnpm-workspace.yaml · tsconfig.base.json · eslint.config.mjs
├─ .env.example · .gitignore · .editorconfig · LICENSE · README.md
├─ apps/
│  ├─ web/
│  │  ├─ app/[locale]/(public)/          home, datasets, compare, findings, findings/[code],
│  │  │                                  methodology/[version], publications, publications/[id],
│  │  │                                  verify/[id], verify/[id]/tamper, claims, assistant,
│  │  │                                  booths, official-links, about, privacy
│  │  ├─ app/[locale]/account/           sign-in, saved, subscriptions, settings
│  │  ├─ app/[locale]/ops/               login, mfa, datasets, runs, findings, publications,
│  │  │                                  claims, booths, methodology, staff, audit, security, jobs
│  │  ├─ app/b/[code]/                   QR booth page (short URL, no locale prefix)
│  │  ├─ app/b/[code]/poster/            printable poster
│  │  ├─ components/                     charts/, LabelBadge, SignalBadge, Disclaimer,
│  │  │                                  LanguageSwitcher, Turnstile, VoiceButton, DataTable
│  │  ├─ lib/                            supabase-server.ts, supabase-browser.ts, api.ts,
│  │  │                                  verifier/ (hash.ts, chain.ts, merkle.worker.ts)
│  │  ├─ middleware.ts                   next-intl routing, session refresh, CSP nonce
│  │  └─ next.config.ts                  output: 'standalone', security headers
│  └─ api/src/
│     ├─ server.ts · app.ts
│     ├─ plugins/                        auth, guards, rate-limit, turnstile, errors, supabase, security-events
│     ├─ routes/                         health.ts, public/*, me/*, staff/*
│     └─ services/                       claims/, qr.ts, uploads.ts, anchor-client.ts,
│                                        llm/ (none, gemini, ollama, validator), alerts.ts
├─ services/
│  ├─ anchor/src/                        server.ts, hmac.ts, anchor.ts, reconcile.ts, balance.ts
│  └─ engine/
│     ├─ pyproject.toml · uv.lock
│     └─ electralens_engine/
│        ├─ cli.py                       el generate | models | vectors | ingest | run | benchmark | worker |
demo-reset
│        ├─ canon.py · normalize.py · merkle.py · hashing.py · manifest.py · schemas.py
│        ├─ csv_io.py · vectors.py · codegen.py
│        ├─ models/                      generated pydantic models (el models --write)
│        ├─ generator/                   names, geography, roll, versions, anomalies, booths
│        ├─ ingest/                      validate, classify, report
│        ├─ analysis/                    load, diff, aggregates, stats, rules (R01–R12), findings, runner,
benchmark
│        ├─ explain/                     render (templates), banned (banned-term guard)
│        ├─ methodology/                 2026.1.json (versioned thresholds)
│        ├─ namekey.py                   phonetic keys for transliterated names (R02)
│        ├─ publish/                     aggregates, suppression, differencing, pii_scan, report
│        └─ worker/                      loop, jobs, db, storage, ots, alerts, retention
├─ packages/
│  ├─ canon/src/                         normalize, jcs, merkle, manifest, hash (browser + Node)
│  ├─ schemas/                           json/*.schema.json → src/zod/*, gen/python/*
```

```
│  └ i18n/                          catalogue/{en,hi}.json (UI text, explanation templates,
│                                   alternatives, limitations), banned-terms.json, src/render.ts
├ contracts/                        contracts/ElectraLensRegistry.sol, test/, ignition/, hardhat.config.ts
├ supabase/                         config.toml, migrations/, seed.sql, tests/*.test.sql
├ test-vectors/canon/               shared canonicalisation vectors
├ e2e/                              playwright.config.ts, demo-flow.spec.ts
├ infra/                            docker-compose.yml, docker/*.Dockerfile, nginx/electralens.conf,
│                                   backup/backup.sh, scripts/{deploy,rollback,healthcheck}.sh
├ docs/                             these documents + RUNBOOK.md
└ .github/                          workflows/{ci,deploy}.yml, dependabot.yml
```

4. Shared conventions

4.1 Identifiers

- **Area codes:** `DEMO-HR` (state) → `DEMO-HR-D01` (district) → `DEMO-HR-AC901` (assembly constituency) → `DEMO-HR-AC901-P047` (part). The `DEMO-` prefix marks synthetic data everywhere, including on-chain (T13).
- **Synthetic geography:** real state and district names (Haryana by default; Rajasthan, Madhya Pradesh and Uttar Pradesh available) make the demo read as Indian data. Below district level everything is fictional. Constituencies are numbered from 901, above every real constituency number, and named " DEMO-n". Parts and booths are invented, and synthetic booths have no coordinates. A synthetic anomaly can never be mistaken for a finding about a real constituency, and a demo QR code can never send anyone to a real building.
- **Publication series:** one series per area a dataset covers, `series_id` = that area's code (for example `DEMO-HR`). On-chain `seriesId = keccak256(utf8(series_id))`.
- **Finding code:** `F-2027-000001`, numbered by the engine within a run and unique per run. Public links use the finding's UUID.
- **Area and source IDs:** UUIDv5 from stable names (`area:<code>`), so the seed, the engine and the worker agree without a lookup.
- **Booth public code:** 10 characters of Crockford base32 from a cryptographic random source (50 bits). Never derived from the station number.
- **Primary keys:** UUID v4 (`gen_random_uuid()`).

4.2 Schemas (one source of truth)

The zod schemas in `packages/schemas/src` are the single source. They're exported as JSON Schema (draft-07) to `packages/schemas/json` (`pnpm --filter @electralens/schemas generate`), and the engine's pydantic models are generated from those files (`uv run el models --write`). Tests fail if either generated output is out of date.

Schema	Fields (summary)	Classification
`electoral_roll_v1` (row)	`record_key`, `ac_code`, `part_no`, `serial_no`, `name_local`, `name_latin`, `relative_name_local`, `relative_name_latin`, `relation_type` (F/M/H/O), `gender` (M/F/T), `age`, `house_no`, `epic_like`, `status` (active/deleted), `deletion_reason` (D dead / S shifted / A absent / R repeated, or null), `qualifying_date`	**Direct identifiers:** names, relative names, `house_no`, `epic_like`, `record_key`. **Quasi-identifiers:** age, gender, part. **Non-identifying:** codes, status, reason.
`polling_stations_v1` (row)	`station_code`, `parts_served[]`, `name{locale}`, `address{locale}`, `lat`, `lng`, `accessibility{ramp, ground_floor, drinking_water, toilet, wheelchair}`, `source_url`	Public facility data
`finding_v1`	As Architecture §9.3	Public after review (row-level evidence excluded)

Schema	Fields (summary)	Classification
`manifest_v1`	As Architecture §8.3	Public
`claim_v1`	`area_code`, `metric`, `period`, `comparator`, `value`, `unit`, `claim_type` (number / cause_or_intent)	Public after moderation
Job payloads	One per job kind (§5.1)	Internal

Localised text is stored as an object keyed by locale (`{"en": "…", "hi": "…"}`), so the third language can be added without any schema change.

The roll schema has **no field for party, candidate, vote share or turnout**. Ingestion rejects unknown columns, so that data can't enter the system (NFR-3).

4.3 Canonicalisation `elcanon-1`

The rules in Architecture §8.1 and §8.2, plus:

- **No binary floating-point numbers in any hashed document.** Decimals are strings with exactly 6 decimal places (`"0.179700"`). Integers must stay within ±2^53. This avoids float-formatting differences between Python and JavaScript.
- Hashes are lowercase hex with no prefix. `0x` is used only on-chain.
- Whitespace is an explicit character set, identical in both languages, because Python's `\s` and JavaScript's `\s` match different characters.
- Text accepts only Basic Multilingual Plane characters (every Indian script is in it), so length limits mean the same in UTF-16 (zod) and code points (Python).
- A float given to a decimal field is formatted at the field's scale and must round-trip exactly. Anything more precise is rejected, never rounded.
- Integers accept ASCII digits only, so `"४२"` is rejected in both languages (Python's `int()` would otherwise accept it).
- CSV parsing belongs to ingestion (Python). The shared vectors work on row objects.
- Shared test vectors in `test-vectors/canon/`: ASCII row; Devanagari supplied as NFC and as NFD (same output); whitespace variants; empty optional field becomes `null`; shuffled row order (same root); CRLF and LF files (same root); two identical rows (both counted); 0 rows (root = SHA-256 of the empty string); 1, 3, 4, 5 and 7 rows (RFC 6962 split points); a one-character change (different root); manifest key ordering; decimals as strings.

4.4 API conventions

- Base path `/api/v1`, JSON only, UTC ISO 8601 timestamps.
- Errors are RFC 9457 `application/problem+json` with a stable `code`, for example `auth.mfa_required`, `workflow.same_person`, `workflow.illegal_transition`, `turnstile.failed`, `rate_limited`.
- Pagination with `limit` (max 100) and `cursor`.
- Staff `POST` requests that create jobs accept an `Idempotency-Key` header.

---

5. Database design (Supabase Postgres)

5.1 Enums

`staff_role` (sysadmin, data_steward, analyst, reviewer, publisher, security_auditor) · `jurisdiction_level` (state, district, ac, part) · `dataset_kind` (electoral_roll, polling_stations) · `permission_basis` (synthetic, public_official, authorised) · `dataset_status` (uploading, validating, quarantined, validated, approved, superseded) · `job_kind` (ingest, analyze, publish_prepare, ots_stamp, ots_upgrade, notify, retention, benchmark) · `job_status` (queued, running, succeeded, failed, dead) · `run_status` (queued, running, ready_for_review, failed, superseded) · `review_decision` (pending,

accepted, downgraded, rejected) · `signal_strength` (strong, moderate, weak, data_quality) · `publication_status` (draft, preparing, in_review, approved, published, retracted, withdrawn) · `approval_step` (review, publish) · `anchor_type` (evm, ots) · `anchor_status` (pending, submitted, confirmed, upgraded, failed) · `claim_verdict` (consistent, contradicted, disputed, cannot_establish) · `claim_status` (checked, in_moderation, published, rejected) · `content_label` (source_data, analytical_finding, user_claim, unverified, confirmed_correction)

5.2 Tables

Table	Key columns	Notes and constraints
`jurisdictions`	id, code (unique), level, parent_id, name (jsonb by locale), is_synthetic	Parent's level must be one above the child's (trigger)
`polling_stations`	id, public_code (unique), part_id, station_no, name and address (jsonb by locale), lat, lng, accessibility (jsonb), parts_served, dataset_version_id, verified_at, is_synthetic, published	`public_code` matches `^[0-9A-HJKMNP-TV-Z]{10}$`
`data_sources`	id, name, publisher, url, permission_basis, licence_note, is_synthetic, is_public, created_by	
`dataset_versions`	id, source_id, kind, label, qualifying_date, roll_stage (draft/final/supplement), schema_version, jurisdiction_id, status, original_path, original_sha256, canonical_path, canonical_root, row_count, salt_path, ingestion_report (jsonb), is_public, uploaded_by, approved_by, approved_at	Root and row count are immutable once `validated` (trigger)
`methodology_versions`	version (pk, e.g. `2026.1`), params (jsonb), params_hash, status (draft/frozen/published), notes, frozen_at, published_at	Immutable once frozen (trigger)
`jobs`	id, kind, status, payload, input_hash, attempts, max_attempts, locked_by, locked_until, last_error, created_by, created_at, updated_at	Partial unique `(kind, input_hash)` while not failed or dead (idempotency)
`audit_runs`	id, baseline_version_id, target_version_id, methodology_version, status, engine_version, image_digest, params_hash, seed, input_roots, output_hash, tests_count, created_by, started_at, finished_at, error	Both versions must be `approved` (checked in `request_audit_run`)
`anomaly_findings`	id, run_id, finding_code, rule_id, rule_version, jurisdiction_id, signal_strength, finding (the complete `finding_v1` document), restricted_evidence_path, review_status, label, published	Stored exactly as the engine produced it. A check ties `finding.finding_id` to the code, and a published finding must be accepted or downgraded and never weak
`finding_reviews`	id, finding_id, reviewer_id, decision, reason, created_at	A reason is required for downgrade or reject
`aggregate_metrics`	id, run_id, dataset_version_id, jurisdiction_id, metric, dims (jsonb), value, suppressed, published	Rows with `published = true` are written **after** suppression
`publications`	id, series_id, sequence, run_id, status, manifest, manifest_hash, previous_publication_id, supersedes_id, report_path, aggregates_path, report_hash, aggregates_hash, created_by, approved_at, published_at, retracted_at, retraction_reason	Unique `(series_id, sequence)`. Manifest is immutable after `in_review`.
`publication_approvals`	id, publication_id, approver_id, step, manifest_hash, decision, reason, created_at	Unique `(publication_id, step)` and `(publication_id, approver_id)`
`blockchain_anchors`	id, publication_id, anchor_type, network, chain_id, contract_address, tx_hash, block_number, log_index, ots_path, status, created_at, confirmed_at	
`claim_submissions`	id, submitter_id (nullable), text, structured, language, status, ip_hash, created_at	`ip_hash` deleted after 30 days

Table	Key columns	Notes and constraints
`claim_assessments`	id, claim_id, verdict, evidence, publication_id, method_version, explanation, assessed_by (null = automatic), created_at	
`profiles`	user_id (pk → auth.users), display_name, preferred_language, notify_email, created_at	Created by a trigger on signup
`staff_assignments`	id, user_id, role, jurisdiction_id (null = all), granted_by, granted_at, revoked_at, revoked_by	Partial unique while not revoked. Written only by `grant_role` / `revoke_role`.
`saved_items`	id, user_id, item_type (publication/finding/booth), item_id, created_at	Unique per user and item
`user_subscriptions`	id, user_id, target_type (jurisdiction/series), target_id, created_at	
`audit_log`	id (identity), at, actor_id, actor_roles, action, target_type, target_id, reason, details	UPDATE and DELETE revoked from every role, plus a trigger that raises on either
`security_events`	id, at, user_id, event_type, ip_hash, details	180-day retention
`incident_records`	id, opened_at, severity, title, summary, status, closed_at, public_note	P2

5.3 Database functions

All are `security definer`, use `set search_path = ''`, check state and roles, and write `audit_log` in the same transaction.

Function	Who can call it	What it enforces
`el.has_role(role, jurisdiction)`, `el.is_staff()`, `el.mfa_ok()`	Used inside policies	Reads `staff_assignments` (not revoked) and requires `aal2`
`el.log(...)`	Internal only	Append-only write
`create_data_source`, `create_dataset_version`, `mark_dataset_uploaded(id, path)`	data_steward	The upload path must be inside the version's quarantine folder. Queues the ingest job.
`complete_ingestion(...)`	Worker	`validating` → `validated` or `quarantined`, with the ingestion report
`create_methodology_draft`, `freeze_methodology`, `publish_methodology`	analyst drafts; a *different* publisher freezes and publishes	Two people per methodology. Frozen parameters can never change (trigger).
`start_run`, `complete_run`	Worker	`queued` → `running` → `ready_for_review` or `failed`
`moderate_claim`, `delete_own_unpublished_claims`	reviewer; the signed-in citizen	Rejection needs a reason; deletion is step 1 of account deletion
`approve_dataset_version(id)`	data_steward	Only from `validated`
`request_audit_run(baseline, target, methodology)`	analyst	Both versions approved, methodology frozen. Creates the run and its job.
`review_finding(id, decision, reason)`	reviewer	Not the run's creator. Reason required.
`create_publication(run_id)`	publisher	Run is `ready_for_review` and every finding has been reviewed. Enqueues `publish_prepare`.
`submit_publication(id)`	Worker (service)	`preparing` → `in_review` once the manifest, suppression and PII scan are done

Function	Who can call it	What it enforces
`approve_publication(id, step, manifest_hash, decision, reason)`	reviewer (review step), publisher (publish step)	Hash matches. Two **different** people, neither the run's creator, each with the right role and `aal2`. Both approvals → `approved`.
`mark_published(id, anchor)`	Anchor service	Only from `approved`
`retract_publication(id, reason)`	publisher	Appends. A retraction is never a delete.
`grant_role(user, role, jurisdiction)`, `revoke_role(assignment)`	sysadmin	Can't grant to themselves
`claim_next_job(kinds, worker, lease_seconds)`, `complete_job(id, result)`, `fail_job(id, error)`	Worker role	`FOR UPDATE SKIP LOCKED`, lease expiry, attempts, dead-lettering
`submit_claim(...)`	API (after Turnstile)	Inserts into the moderation queue

5.4 Row-level security

Table	anon	Citizen	Staff (`aal2` required)
jurisdictions	read all	read all	steward writes through function
polling_stations	read where published	same	steward manages
data_sources, dataset_versions	read granted columns where `is_public`	same	read within scope
methodology_versions	read where published	same	analyst drafts, publisher freezes and publishes
jobs	—	—	read within scope
audit_runs	read when published	same	read within scope
anomaly_findings	read published, not `weak`, without `restricted_evidence_path`	same	read within scope
finding_reviews	— (counts appear in the report)	—	read; writes through function
aggregate_metrics	read `published = true` rows	same	read all
publications, blockchain_anchors	read published and retracted	same	read all
publication_approvals	read step, role and time (no approver ID) for public publications	same	read all
claim_submissions, claim_assessments	read published	own rows	reviewer reads all
profiles, saved_items, user_subscriptions	—	own rows only	—
staff_assignments	—	own rows	sysadmin reads all
audit_log, security_events, incident_records	—	—	auditor and sysadmin read

Anonymous column access uses column-level `GRANT`s, so internal columns such as storage paths are never readable.

5.5 Storage buckets

Bucket	Access	Contents
`quarantine`	Private. Writes only through 15-minute signed upload URLs from the API.	Uploaded originals before validation

Bucket	Access	Contents
`datasets-restricted`	Private. Service role only. Analysts and reviewers get 5-minute signed read URLs (audit-logged).	Originals, canonical Parquet, salts, row-level evidence
`public-artifacts`	Public read. Written only by the service role after publication.	Manifests, reports, aggregates, OTS proofs, synthetic demo datasets and their salts

The free plan limits each file to 50 MB. A canonical roll of about 115,000 rows is roughly 50 MB as plain JSON lines, so canonical files are stored gzip-compressed (about 8 MB).

---

6. Build checklist — foundations and core engine

B00 Foundations · S0 · hours 0–1

- [ ] **B00.01** Clone the shared repo. `.gitignore` covers `.env*`, `secrets/`, `node_modules`, `.venv`, generated data, `supabase/.temp`. [NFR-2] P0
- [x] **B00.02** pnpm workspace, strict `tsconfig.base.json`, ESLint, Prettier. [NFR-12] P0
- [x] **B00.03** `services/engine` as a uv project on Python 3.12 with ruff and pytest. [NFR-12] P0
- [x] **B00.04** `supabase init`. The local stack starts with `npx supabase start`. [NFR-12] P0
- [x] **B00.05** `.env.example` lists every variable in §2 with no values. README quick start. [NFR-2] P0
- [ ] **B00.06** CI workflow running lint, typecheck, vitest and pytest. [NFR-12] P0
- [x] **B00.07** Licence file (Apache-2.0 [P]). P0
- [x] **B00.08** Dependabot for npm, Python, GitHub Actions and Docker. [T23] P1

B01 Shared schemas and canonicaliser · S1 · hours 1–4

- [x] **B01.01** JSON Schemas from §4.2. [FR-ING-1, FR-AUD-5, FR-INT-2] P0
- [x] **B01.02** Export JSON Schema from the zod source and generate pydantic models from it, with freshness tests. [NFR-12] P0
- [x] **B01.03** `normalize` in TS and Python: NFC, trim, whitespace collapse, empty → null, uppercase codes, ISO dates, decimals as strings. [FR-INT-1] P0
- [x] **B01.04** JCS serialisation (`canonicalize` in TS, `rfc8785` in Python). [FR-INT-1] P0
- [x] **B01.05** RFC 6962 Merkle tree with 0x00/0x01 prefixes and per-dataset salt: root, inclusion proof, proof verification, in both languages. [FR-ING-6, FR-INT-1] P0
- [x] **B01.06** Manifest builder and `manifest_hash`. [FR-INT-2] P0
- [x] **B01.07** Test vectors (§4.3) with parity tests in vitest and pytest. [FR-INT-7, AC-7] P0

B02 Synthetic data generator · S1 · hours 1–4

Command: `el generate --seed 42 --state HR --acs 3 --out data/demo`. Version 2 is derived from version 1 with normal background churn (deaths, shifting, first-time voters, corrections) plus injected anomalies.

- [x] **B02.01** Geography: a real state and its real districts, then fictional constituencies (901+) and parts, named in English and Hindi. The third language is added once chosen (D4). [FR-AUD-1] P0
- [x] **B02.02** Electors: Devanagari and Latin names and relative names, gender, realistic age profile, house numbers, synthetic EPIC-format IDs (restricted only), at most 1,200 per part. [FR-AUD-1] P0
- [x] **B02.03** Version evolution with background churn and deletion reason codes. [FR-AUD-1, FR-AUD-2] P0
- [x] **B02.04** Anomaly injector for every rule R01–R12, **plus innocent look-alikes** (a hostel address, a part reorganisation), writing `ground_truth.json`. [FR-AUD-1, FR-AUD-7] P0
- [x] **B02.05** Synthetic polling stations: "DEMO" and "fictional" in every name, invented addresses, **no coordinates**, accessibility flags. [FR-QR-4] P0

- [x] **B02.06** Determinism test: same seed gives byte-identical files. [FR-AUD-6] P0
- [x] **B02.07** Every file and record carries `is_synthetic`. Names are random combinations from lists. [C2] P0

B03 Ingestion · S2 / S5

- [ ] **B03.01** API creates a dataset version with provenance: source, permission basis, retrieval URL and time, kind, schema version, area scope. [FR-ING-2] P0
- [ ] **B03.02** Signed upload URL to `quarantine/{version}/original.{csv|parquet}`. Expires in 15 minutes, 50 MB limit, allowed content types only. [FR-ING-1] P0
- [ ] **B03.03** Worker validation with Polars and explicit types: schema, ranges, enums, required fields, references to `jurisdictions`. No formula evaluation. [FR-ING-3, T03] P0
- [ ] **B03.04** Column classification (direct / quasi / non-identifying) from schema metadata, recorded in the report. [FR-ING-5] P0
- [ ] **B03.05** Ingestion report: counts and errors by type with row numbers **but no values**. Invalid → `quarantined`, file kept. [FR-ING-4] P0
- [ ] **B03.06** Original kept with its SHA-256. Canonical Parquet and a 32-byte salt stored in `datasets-restricted`. Root and row count saved. [FR-ING-6, FR-ING-7] P0
- [ ] **B03.07** Steward approval. Analysts can use only `approved` versions. [FR-ING-9] P1 (the demo script approves automatically)
- [ ] **B03.08** No URL-import route exists, and a test asserts it. [FR-ING-8, T08] P0
- [ ] **B03.09** `el ingest` CLI uses the same code path, for demo seeding. [AC-1] P0
- [ ] **B03.10** Unknown columns are rejected, so party or vote data can't enter. [NFR-3] P0

B04 Audit engine · S2 · hours 3–8

Each rule is a pure function `rule(ctx) -> list[Finding]`. The runner loads both canonical files, diffs them, builds aggregates, runs **all** rules on **all** parts, applies Benjamini–Hochberg per rule across the run, classifies signal strength, renders explanations, writes row-level evidence to restricted storage, and commits findings and aggregates in one transaction.

- [x] **B04.01** Diff: additions, deletions with reasons, field-level corrections, per part and constituency. [FR-AUD-2] P0
- [x] **B04.02** Aggregates: electors, additions, deletions by reason, corrections, gender, age bands, at part / constituency / district / state level. [FR-PUB-2] P0
- [x] **B04.03** Stats library: beta-binomial with a robust baseline (interquartile-trimmed rate, MAD-based overdispersion), binomial and Fisher exact tests, Wilson interval, Benjamini–Hochberg. Tested against SciPy and hand-calculated values. [FR-AUD-4] P0
- [x] **B04.04** P0 rules: R01 exact duplicate, R02 likely duplicate, R03 impossible age, R04 age drift, R05 deletion rate, R06 addition rate, R08 high-occupancy address, R10 missing fields. [FR-AUD-3] P0
- [x] **B04.05** P1 rules: R07 part appeared or disappeared, R09 gender-ratio shift, R11 deletion-reason mix, R12 18–19 cohort shift. [FR-AUD-3] P1
- [x] **B04.06** Signal strength (strong / moderate / weak / data quality) from the methodology thresholds. Weak findings are staff-only. [FR-AUD-5] P0
- [x] **B04.07** Finding builder emitting `finding_v1`: evidence, baseline, criterion, alternatives, limitations, tests in run. Row-level evidence goes to restricted storage only. [FR-AUD-5, NFR-1] P0
- [x] **B04.08** No area-filter parameter exists. Every run covers every part. [FR-AUD-9, T20] P0
- [x] **B04.09** Reproducibility record (engine source hash, parameter hash, input roots, output hash) and a golden-run test. The Git SHA and container image digest are added when the engine runs from a commit in Docker (S8). [FR-AUD-6, AC-2] P0
- [x] **B04.10** Benchmark job: precision and recall per rule against `ground_truth.json`, stored with the methodology version. [FR-AUD-7, AC-8] P0
- [ ] **B04.11** ML gate documented: no ML rule ships unless it beats the rules on the benchmark. [FR-AUD-8] P2

- [ ] **B04.12** A 200k-row run timed on the VPS. [NFR-5] P1. *Locally (laptop): two versions of about 115,000 rows take about 20 s to canonicalise and load, plus 2.5 s of analysis.*

B05 Explanations and languages · S2 / S6

- [ ] **B05.01** Template catalogue per rule × signal strength × language (en, hi, third) with placeholders and Indian digit grouping. [FR-EXP-1, FR-AST-2] P0. *English and Hindi done; the third language waits on decision D4.*
- [x] **B05.02** Alternative explanations: at least two per rule, in all languages. [FR-EXP-2, AC-9] P0
- [x] **B05.03** Limitations catalogue (synthetic data, missing reason codes, small parts, and so on). [FR-AUD-5] P0
- [x] **B05.04** Banned-term lists (fraud, rigged, stolen, fake voters, party names), checked on every generated explanation and by a test over every template. Names can't enter explanations at all, because templates only receive aggregate evidence. [FR-EXP-4, AC-10] P0
- [x] **B05.05** One catalogue, rendered by both Python (worker) and TS (web). [FR-EXP-1] P0
- [ ] **B05.06** LLM adapter interface (`none` by default, `gemini`, `ollama`). Its input type accepts public evidence only. [FR-EXP-3] P1
- [ ] **B05.07** LLM output validator: numbers and places must appear in the evidence, banned terms blocked, length capped, template fallback, rejection counter. [FR-EXP-3, T15] P1
- [ ] **B05.08** Fluent-speaker review record for the Hindi and third-language strings. [NFR-8] P0

---

7. Build checklist — data, API and integrity

B06 Database · S3 · hours 3–8

- [x] **B06.01** Migration `0001`: enums (§5.1) and extensions (pgTAP for tests). P0
- [x] **B06.02** `0002`: reference and lineage tables (`jurisdictions`, `polling_stations`, `data_sources`, `dataset_versions`, `methodology_versions`). P0
- [x] **B06.03** `0003`: analysis tables (`jobs`, `audit_runs`, `anomaly_findings`, `finding_reviews`, `aggregate_metrics`). P0
- [x] **B06.04** `0004`: publication tables (`publications`, `publication_approvals`, `blockchain_anchors`). P0
- [x] **B06.05** `0005`: claims (`claim_submissions`, `claim_assessments`). P0
- [x] **B06.06** `0006`: accounts (`profiles`, `staff_assignments`, `saved_items`, `user_subscriptions`) and the profile-on-signup trigger. P0
- [x] **B06.07** `0007`: governance (`audit_log` append-only with revokes and trigger, `security_events`, `incident_records`). [FR-GOV-3] P0
- [x] **B06.08** `0008`: helper functions in schema `el` with `search_path = ''`. [T04] P0
- [x] **B06.09** `0009`: workflow functions (§5.3), including the two-person rule. [FR-GOV-2] P0
- [x] **B06.10** `0010`: RLS enabled on every table, policies per §5.4, column grants for anon. [AC-4] P0
- [x] **B06.11** `0011`: storage buckets and policies (§5.5). P0
- [x] **B06.12** Custom access token hook adds a `staff_roles` claim for the UI only. [FR-ACC-4] P1
- [x] **B06.13** Indexes: every foreign key, partial indexes on status columns, the job-queue index `(kind, created_at) WHERE status = 'queued'`, findings by run and area, publications by series. P0
- [x] **B06.14** Fictional `seed.sql`: demo jurisdictions and methodology `2026.1`. No passwords in seeds. P0
- [x] **B06.15** pgTAP tests: RLS matrix per table × role, separation of duties, `audit_log` immutability, illegal state transitions. [AC-4, AC-5] P0
- [ ] **B06.16** Retention: versioned `retention.yaml` and a `retention` job (security events 180 days, unpublished claims 1 year, IP hashes 30 days). [Threat model §5.1] P1

B07 API · S5 · hours 7–11

Group	Routes	Guard
Health	`GET /health`, `GET /ready`	none
Public	`GET jurisdictions`, `GET datasets`, `GET datasets/{id}`, `GET comparisons`, `GET findings`, `GET findings/{code}`, `GET methodology/{version}`, `GET publications`, `GET publications/{id}`, `GET verify/{id}`, `GET booths`, `GET booths/{code}`, `GET booths/{code}/qr.svg`, `GET official-links`, `GET openapi.json`	none (RLS as anon)
Public writes	`POST claims/check`, `POST claims`, `POST assistant/ask` (P2)	Turnstile + rate limit
Citizen	`GET/PATCH/DELETE me`, `GET/POST/DELETE me/saved`, `GET/POST/DELETE me/subscriptions`, `GET me/claims`	signed in
Steward	`GET/POST staff/datasets`, `POST staff/datasets/{id}/uploaded`, `POST staff/datasets/{id}/approve`, `POST staff/booths/import`, `POST staff/booths/{id}/publish`	role + aal2
Analyst	`GET/POST staff/runs`, `GET staff/runs/{id}`, `GET staff/findings/{id}/evidence`, `GET/POST staff/methodology`	role + aal2
Reviewer	`POST staff/findings/{id}/review`, `POST staff/publications/{id}/approve` (review step), `GET staff/claims`, `POST staff/claims/{id}/moderate`	role + aal2
Publisher	`GET/POST staff/publications`, `POST staff/publications/{id}/approve` (publish step), `POST staff/publications/{id}/retract`, `POST staff/methodology/{v}/publish`	role + aal2
Auditor / sysadmin	`GET staff/audit-log`, `GET staff/security-events`, `GET/POST staff/incidents` (P2)	role + aal2
Sysadmin	`GET staff/users`, `POST staff/users/invite`, `PUT staff/users/{id}/roles`, `DELETE staff/users/{id}/roles/{assignment}`	role + aal2
Jobs	`GET staff/jobs`, `POST staff/jobs/{id}/retry`	any staff role + aal2
Internal (anchor)	`POST /internal/anchor`, `GET /internal/health`	Docker network + HMAC

- [ ] **B07.01** Fastify skeleton: zod type provider, pino redaction (authorization, cookie, email, IP), problem+json handler, request IDs. [NFR-11] P0
- [ ] **B07.02** Auth plugin: verify the Supabase JWT, read `aal`, load active roles, create a per-request Supabase client **with the user's token**. [FR-ACC-5] P0
- [ ] **B07.03** Guards `requireUser`, `requireStaff(roles)`, `requireAal2`, with a route × role test for every route. [FR-ACC-4, AC-4] P0
- [ ] **B07.04** Rate limits per IP and per user (public GET 120/min, claims 10/min, sign-in related 5/min). 429 as problem+json. Repeated hits create security events. [T10] P0
- [ ] **B07.05** Turnstile service: `siteverify`, hostname and action checks, fails closed. [FR-CLM-5] P0
- [ ] **B07.06** Public routes with `Cache-Control: s-maxage=60, stale-while-revalidate`. [FR-PUB-*] P0
- [ ] **B07.07** Citizen routes. [FR-ACC-1–3] P1
- [ ] **B07.08** Staff routes that call the database workflow functions with the user's JWT. [FR-GOV-*] P0
- [ ] **B07.09** Signed URLs for uploads (quarantine) and restricted evidence (5 minutes, audit-logged). [FR-ING-1, T05] P0
- [ ] **B07.10** Anchor client signing requests with HMAC over timestamp, nonce and body hash. [FR-INT-3] P0
- [ ] **B07.11** Security events for 401/403 bursts, Turnstile failures, rate-limit hits and role changes. [FR-GOV-6, T09] P0
- [ ] **B07.12** OpenAPI document generated from the zod schemas at `/api/v1/openapi.json`, for journalists. [FR-PUB-8] P1
- [ ] **B07.13** `/health` (liveness) and `/ready` (database and storage reachable). [NFR-11] P0

B08 Integrity: contract, anchor service, OpenTimestamps · S4 · hours 3–8

- [ ] **B08.01** `ElectraLensRegistry.sol` (Solidity 0.8.x, OpenZeppelin `AccessControl`): `constructor(admin, publisher)`, `anchor`, `retract`, `latest`, `entry`, `count`, events `Anchored` and `Retracted`, custom errors. No upgradeability, no overwrite, no delete. [FR-INT-3] P0
- [ ] **B08.02** Contract tests: happy path; duplicate hash reverts; wrong `expectedPrevious` reverts; non-publisher reverts; after the admin revokes the publisher, anchoring reverts; retract emits an event and removes nothing; sequence increments; gas report. [FR-INT-3] P0
- [ ] **B08.03** Deploy to Hoodi with Hardhat Ignition. The deployer is the **new** publisher wallet. Your MetaMask address is passed in as admin, so your personal key never touches the server or the repo. Record the address and deploy block. [FR-INT-3, D5] P0
- [ ] **B08.04** Verify the contract source on a Hoodi block explorer, if one supports it for free [A]. [FR-PUB-5] P1
- [ ] **B08.05** Anchor service: internal-only HTTP, HMAC check with a ±60 s window and a nonce replay cache. [TB4] P0
- [ ] **B08.06** Anchor service reloads the publication, **recomputes the manifest hash itself**, and checks status `approved` plus two valid approvals bound to that hash. Otherwise it refuses and records a security event. [FR-INT-2, T16] P0
- [ ] **B08.07** Transactions go through a single-flight queue with nonce management and a fee bump after a timeout. It waits for 1 confirmation, records transaction hash, block and log index, then calls `mark_published`. [FR-INT-5] P0
- [ ] **B08.08** Failure path: retries with backoff. The publication shows "anchor pending". Alert after 1 hour. [Architecture §14] P1
- [ ] **B08.09** Reconciliation every 10 minutes: read `Anchored` and `Retracted` logs since the deploy block. Any event without a matching published publication → critical alert and security event. [T16, T17] P1
- [ ] **B08.10** Alert when the publisher wallet's balance runs low. [T17] P1
- [ ] **B08.11** Worker job `ots_stamp`: stamp the manifest hash with OpenTimestamps, store the pending `.ots` file in `public-artifacts`, add an `ots` anchor row. [FR-INT-4] P1
- [ ] **B08.12** Job `ots_upgrade` runs hourly until complete, then marks the anchor `upgraded` with the Bitcoin block height. [FR-INT-4] P1
- [ ] **B08.13** The verifier shows OTS status and offers the `.ots` download with instructions for checking it with the official client. [FR-INT-5] P1

---

8. Build checklist — public experience

B09 Public web · S6 · hours 12–17

Route	Purpose
`/[locale]`	Home: published datasets, latest revision summary, what ElectraLens is and isn't, entry points
`/[locale]/datasets`	Versions with provenance, row counts, roots, synthetic flags
`/[locale]/compare`	Area and version comparison with drill-down
`/[locale]/findings`, `/findings/[code]`	Findings list and detail
`/[locale]/methodology/[version]`	Rules, thresholds, tests, limitations, benchmark
`/[locale]/publications`, `/publications/[id]`	Series history, corrections, retractions, anchors
`/[locale]/verify/[id]`, `/verify/[id]/tamper`	Independent verification, tamper demo
`/[locale]/claims`	Claim checker
`/[locale]/assistant`	Guided citizen assistant

Route	Purpose
`/[locale]/booths`	Booth search by area
`/b/[code]`, `/b/[code]/poster`	QR booth page, printable poster
`/[locale]/official-links`, `/about`, `/privacy`	Official services, what ElectraLens is, privacy
`/[locale]/account/*`	Citizen sign-in, saved items, subscriptions, settings
`/[locale]/ops/*`	Operations console (B15)

- [ ] **B09.01** Layout: header, language switcher (en / hi / third), a persistent "independent, not affiliated with ECI" notice, footer with links. [FR-PUB-1, T25, NFR-13] P0
- [ ] **B09.02** Home page. [FR-PUB-1] P0
- [ ] **B09.03** Datasets page. [FR-PUB-6] P0
- [ ] **B09.04** Compare page: SVG bar charts plus a data table, drill-down state → district → constituency → part, "< 10" suppression markers. [FR-PUB-2, FR-PUB-9, NFR-7] P0
- [ ] **B09.05** Findings list with filters (rule, area, strength, review status) and per-run counts, **including findings rejected in review**. [FR-PUB-3, T20] P0
- [ ] **B09.06** Finding detail: evidence table, baseline, criterion, signal strength with interval, explanation, alternatives shown as prominently as the evidence, limitations, review status, content label, permalink, share card with disclaimer. [FR-PUB-3, FR-PUB-7, AC-9, T24] P0
- [ ] **B09.07** Methodology page: rules table, thresholds, statistical tests, what signal strength means, limitations, benchmark precision and recall, change log. [FR-PUB-4, FR-AUD-7] P0
- [ ] **B09.08** Publications page: sequence per series, linked corrections and retractions, anchor status. [FR-PUB-6, FR-GOV-4] P0
- [ ] **B09.09** Downloads: aggregates as CSV and JSON, report as JSON, each with its hash. CSV cells starting with `= + - @` are escaped. [FR-PUB-8, T03] P1
- [ ] **B09.10** Official-links page plus contextual links (Forms 6/7/8, roll search, ECINET), clearly marked external and official. [FR-PUB-10, FR-AST-1] P0
- [ ] **B09.11** About page (is / is not) and privacy page (data inventory and retention). [NFR-13] P0
- [ ] **B09.12** One `LabelBadge` component used everywhere: Source data / Analytical finding / User-submitted claim / Unverified / Confirmed correction. [FR-PUB-7] P0
- [ ] **B09.13** "Data as of ..." banner served from cache when Supabase is unreachable. [NFR-6] P1
- [ ] **B09.14** Accessibility pass: keyboard, focus, contrast, labels, chart tables, `lang` attributes. [NFR-7] P0
- [ ] **B09.15** Performance budget: minimal client JS on public routes; Lighthouse mobile check. [NFR-5, NFR-9] P1

B10 Verification and tamper demo · S6

- [ ] **B10.01** Load the manifest, report and aggregates from `public-artifacts` and recompute hashes in the browser (WebCrypto + `packages/canon`). [FR-PUB-5, FR-INT-5] P0
- [ ] **B10.02** Read the chain directly from a public Hoodi RPC (read-only ethers provider), compare with `entry(seriesId, sequence)`, and show the transaction, block, time, previous link and an explorer link. [FR-INT-5, TB9] P0
- [ ] **B10.03** Result states: MATCH, MISMATCH, ANCHOR PENDING, RETRACTED, NETWORK UNAVAILABLE. [FR-INT-5] P0
- [ ] **B10.04** Full synthetic-dataset verification: download canonical rows and salt, rebuild the Merkle root in a Web Worker. [Architecture DF4] P0
- [ ] **B10.05** Tamper demo: edit one record in a local copy, recompute, show MISMATCH and **which leaf changed** using inclusion proofs. Synthetic data only. [FR-INT-6, AC-6] P0
- [ ] **B10.06** OTS panel (B08.13). [FR-INT-4] P1

- [ ] **B10.07** "What this proves / what it doesn't prove" box (Architecture §8.5). [FR-INT-5] P0

B11 Claim checker · S6

A claim is `{area_code, metric, period, comparator, value, unit, claim_type}`. Metrics: additions, deletions, deletions by reason, corrections, net change, electors. Tolerance [P]: counts within max(1 %, 10), percentages within 0.5 points.

- [ ] **B11.01** Structured form in three languages. [FR-CLM-1] P0
- [ ] **B11.02** Evaluator in the API: map the claim to published aggregates, apply the tolerance, return one of four verdicts, record the method version. **Disputed** means published sources disagree. **Cannot be established** means no published data covers it. [FR-CLM-3] P0
- [ ] **B11.03** `claim_type = cause_or_intent` always returns "Cannot be established", with an explanation. [FR-CLM-4, AC-12] P0
- [ ] **B11.04** Explanation from templates with the exact numbers and a link to the manifest. [FR-CLM-3] P0
- [ ] **B11.05** Turnstile and rate limits on check and submit. Submissions go to moderation and are never auto-published. [FR-CLM-5] P1
- [ ] **B11.06** Moderation queue for reviewers: publish or reject with a reason. Published claims carry the "User-submitted claim" label and their verdict. [FR-CLM-5, FR-PUB-7] P1
- [ ] **B11.07** Free text parsed into the structured form by the LLM, then confirmed by the user. [FR-CLM-2] P1
- [ ] **B11.08** Prepared test claims for every verdict. [AC-12] P0

B12 Citizen assistant and voice · S6

- [ ] **B12.01** Guided flows (a decision tree, no LLM): check my registration → official link; apply or correct (Forms 6/7/8 in plain words) → official links; find my booth → booth search; understand a change → compare; check a claim → claim checker. [FR-AST-1] P0
- [ ] **B12.02** All flows in three languages. [FR-AST-2] P0
- [ ] **B12.03** Voice input (`SpeechRecognition`, language-tagged) and read-aloud (`speechSynthesis`) where the browser supports them, with a privacy notice. Hidden where unsupported. [FR-AST-3] P1
- [ ] **B12.04** Free-text Q&A grounded only in published content and official links, citing sources, with template fallback. [FR-AST-4] P2

B13 Booths and QR codes · S6

- [ ] **B13.01** Booth import: a `polling_stations_v1` file goes through ingestion and approval, then is published. [FR-QR-4] P0
- [ ] **B13.02** `public_code` generator (§4.1), unique. [FR-QR-2] P0
- [ ] **B13.03** Booth page `/b/{code}`: name, address, parts served, accessibility, source, last verified, official links, "not an official document", DEMO watermark for synthetic data. Server-rendered and cacheable. [FR-QR-1, FR-QR-4] P0
- [ ] **B13.04** Booth search by area only. There is no search by person. [FR-AST-1] P0
- [ ] **B13.05** QR SVG endpoint encoding only `https://<host>/b/<code>`, with a decode test. [FR-QR-2, AC-11] P0
- [ ] **B13.06** Printable A4 poster per booth: QR code and notice, print CSS. [FR-QR-3] P1
- [ ] **B13.07** No per-voter QR route exists, and a test asserts it. [FR-QR-5] P0
- [ ] **B13.08** Booth views are never linked to accounts, and query strings aren't logged. [Threat model §5.4] P0

---

9. Build checklist — accounts, operations console and governance

B14 Accounts · S6 / S7

- [ ] **B14.01** Supabase Auth: Google OAuth, email magic link, custom SMTP (free sender), redirect URLs, and Supabase's built-in CAPTCHA protection set to Turnstile. [FR-ACC-1, T09] P1

- [ ] **B14.02** Citizen sign-in pages with `@supabase/ssr` cookies. No EPIC field anywhere, and a test greps for it. [FR-ACC-1] P1
- [ ] **B14.03** Profile: optional display name, language, notification preferences. [FR-ACC-2] P1
- [ ] **B14.04** Saved items (publications, findings, booths) and subscriptions (area or series). [FR-ACC-2, US-C6] P1
- [ ] **B14.05** Alert job: a new publication in a followed area or series triggers an email digest. [US-C6] P1
- [ ] **B14.06** Self-service account deletion: profile, saved items, subscriptions, unpublished claims and the auth user. [FR-ACC-3] P1
- [ ] **B14.07** Staff invites by the sysadmin: create the user through the admin API, add the assignment, send the invite. The first sign-in forces TOTP enrolment. [FR-ACC-4, FR-ACC-5] P0
- [ ] **B14.08** Staff passwords of at least 14 characters (Supabase password policy), TOTP enrolment and challenge screens, `aal2` required for `/ops`. [FR-ACC-5] P0
- [ ] **B14.09** Roles scoped by area. Revocation takes effect on the next request, with a test. [FR-ACC-6] P1
- [ ] **B14.10** Short idle timeout for staff, and sign-out everywhere when a role is revoked. [T02] P1

B15 Operations console and governance · S7 · hours 14–18

- [ ] **B15.01** `/ops` shell with role-aware navigation. The UI uses role hints, while the API and RLS enforce access. [FR-GOV-1] P0
- [ ] **B15.02** Steward: create a dataset version, upload, read the ingestion report, approve; booth import. [US-S1] P0
- [ ] **B15.03** Analyst: start a run (baseline, target, methodology), watch the job, inspect findings and restricted evidence through a signed-URL viewer. [US-S2] P0
- [ ] **B15.04** Reviewer: review findings with a reason (blocked on own runs), approve the review step, moderate claims. [US-S3] P0
- [ ] **B15.05** Publisher: create a publication from a run, view the manifest and its diff from the previous one, approve the publish step, retract or correct with a reason. [US-S4, US-S5] P0
- [ ] **B15.06** The two-person rule is enforced in the database and shown as a clear error message. [FR-GOV-2, AC-5] P0
- [ ] **B15.07** A correction creates a new linked version (`supersedes_id`). A retraction appends. Nothing is deleted. [FR-GOV-4] P0
- [ ] **B15.08** Auditor: read-only audit log and security-event viewers with filters. [US-S6, FR-GOV-3] P1
- [ ] **B15.09** Sysadmin: staff list, invite, grant and revoke scoped roles. Can't publish or review (enforced). [US-S7] P1
- [ ] **B15.10** Job dashboard: status, attempts, errors, retry. [FR-GOV-5] P1
- [ ] **B15.11** Incident records and security-event views. [FR-GOV-6] P2
- [ ] **B15.12** Methodology versions: draft, freeze (immutable once any run uses it), publish. [T20, FR-PUB-4] P0

---

10. Build checklist — privacy and security (cross-cutting)

B16 Privacy and disclosure control

- [ ] **B16.01** Data tiers enforced: row-level data only in `datasets-restricted`. Database tables hold aggregates only (schema review). [Architecture §6] P0
- [ ] **B16.02** Suppression engine: cells of 1–9 suppressed (k = 10), complementary suppression, nothing below part level, cross-tabs only at constituency level and above, rounding to 5 for sub-constituency cross-tabs. [FR-PUB-9] P0
- [ ] **B16.03** Release-differencing check against the previous publication and overlapping breakdowns. It blocks publication on failure. [T11] P1
- [ ] **B16.04** PII scanner (regex plus dictionaries: synthetic name lists, EPIC pattern `[A-Z]{3}[0-9]{7}`, house-number patterns) over every public artifact in the publish pipeline, and over API response fixtures in CI. [NFR-1, AC-3] P0
- [ ] **B16.05** Log redaction. IP addresses stored only as salted hashes, with a rotating salt. nginx logs kept 14 days. [NFR-1] P0

- [ ] **B16.06** The LLM gateway's input type accepts only public evidence objects. [TB8] P1
- [ ] **B16.07** Privacy page content matches the inventory in Threat model §5.1. P0
- [ ] **B16.08** Account deletion test (B14.06). [FR-ACC-3] P1
- [ ] **B16.09** No trackers or third-party scripts except Turnstile. Fonts self-hosted. A CSP test checks this. P0

B17 Security hardening

- [ ] **B17.01** CSP with nonces. `script-src 'self' 'nonce-…' challenges.cloudflare.com`; `connect-src` limited to self, Supabase and the RPC; `frame-src challenges.cloudflare.com`. Also HSTS, `X-Content-Type-Options`, `Referrer-Policy`, and `Permissions-Policy` (`microphone=(self)` for voice). [T06] P0
- [ ] **B17.02** ESLint rule against `dangerouslySetInnerHTML`. [T06] P0
- [ ] **B17.03** Origin check on Next.js server actions. The API accepts bearer tokens only. [T07] P0
- [ ] **B17.04** Secrets only in Docker secrets. CI checks the built `apps/web` output for service-role keys and secret-like strings. [NFR-2] P0
- [ ] **B17.05** Containers: non-root, read-only root filesystem, tmpfs, `cap_drop: ALL`, `no-new-privileges`, memory and CPU limits, healthchecks. [T22] P0
- [ ] **B17.06** Own Unix user, directory and compose network. No secrets shared with the other app. [T22] P0
- [ ] **B17.07** nginx: Cloudflare IP allow-list and `real_ip` (if D3 = yes), `limit_req` zones, 1 MB body limit, modern TLS. [TB2, T19] P0
- [ ] **B17.08** SSH and firewall review: key-only login, no root login, only ports 22/80/443, fail2ban. Change only what is safe for the other app. P1
- [ ] **B17.09** `npm audit` and `pip-audit` in CI, lockfiles, base images pinned by digest. [T23] P1
- [ ] **B17.10** Admin wallet kept offline. The publisher hot wallet holds a minimal balance. [T17] P0
- [ ] **B17.11** Alerts on role grants, new MFA factors and unusual sign-ins. [T02] P1
- [ ] **B17.12** OWASP ZAP baseline scan against the live site (free). [Threat model §4] P1

---

11. Build checklist — deployment and operations · S8 · hours 17–20

- [ ] **B18.01** Multi-stage Dockerfiles: Next.js standalone, Fastify build, anchor build, Python slim with `uv sync --frozen`. [NFR-4, NFR-12] P0
- [ ] **B18.02** `docker-compose.yml`: project `electralens`, own network, secrets, limits, healthchecks, restart policy, ports bound to 127.0.0.1. [Architecture §15] P0
- [ ] **B18.03** Supabase project (free tier, Mumbai region): migrations applied; auth providers, SMTP, hook and CAPTCHA configured; buckets created. P0
- [ ] **B18.04** DNS record for the subdomain (Cloudflare proxy if D3 = yes) and a TLS certificate (certbot or Cloudflare Origin CA). [D2, D3] P0
- [ ] **B18.05** nginx server block deployed, `nginx -t` passes, and both sites are checked with curl so the other app is confirmed unaffected. [C5] P0
- [ ] **B18.06** Turnstile widget (site key and secret) for the subdomain. [FR-CLM-5] P0
- [ ] **B18.07** Registry deployed (B08.03) and its address in the environment. [FR-INT-3] P0
- [ ] **B18.08** Backup cron: nightly `pg_dump` → `age` encryption → keep 14 daily and 8 weekly. First restore drill into local Supabase, timed. [T18, T21] P0
- [ ] **B18.09** Free external uptime monitor on `/` and `/api/v1/health`, plus an alert channel. [NFR-6, NFR-11] P0
- [ ] **B18.10** Supabase keep-alive (worker polling plus a daily health query), and a check that the project isn't paused. P0
- [ ] **B18.11** `deploy.sh` (pull tag, compose up, wait for health) and `rollback.sh` (previous tag). P0
- [ ] **B18.12** Log rotation: Docker json-file 10 MB × 3, nginx logrotate 14 days. [NFR-11] P0
- [ ] **B18.13** GitHub Actions: `ci.yml` runs every test; `deploy.yml` is manually triggered and deploys over SSH. P1

- [ ] **B18.14** `docs/RUNBOOK.md`: deploy, rollback, restore, key rotation, incident steps. [Threat model recovery steps] P1
- [ ] **B18.15** Cost check: every service on a free tier, no add-on that needs a card. [NFR-10, C1] P0

12. Build checklist — testing and quality gates

- [ ] **B19.01** AC-1: Playwright end-to-end on production: generate → ingest → run → review → two-person publish → anchor → verify → tamper, in under 5 minutes. P0
- [ ] **B19.02** AC-2: golden run gives identical output hashes. P0
- [ ] **B19.03** AC-3: PII scan of public responses and files. P0
- [x] **B19.04** AC-4: pgTAP RLS matrix. P0
- [x] **B19.05** AC-5: separation-of-duties tests. P0
- [ ] **B19.06** AC-6: tamper detection test. P0
- [ ] **B19.07** AC-7: cross-language canonicalisation vectors. P0
- [ ] **B19.08** AC-8: benchmark computed and displayed. P0
- [ ] **B19.09** AC-9: every finding complete in all three languages. P0
- [ ] **B19.10** AC-10: banned terms in templates (and in LLM output when enabled). P0
- [ ] **B19.11** AC-11: QR decode test. P0
- [ ] **B19.12** AC-12: claim verdict fixtures. P0
- [ ] **B19.13** API route × role authorisation tests, including IDOR attempts. [T05] P0
- [ ] **B19.14** Upload fuzzing with malformed CSV and Parquet. [T03] P1
- [ ] **B19.15** Contract tests (B08.02). P0
- [ ] **B19.16** Lighthouse and axe checks on key pages. [NFR-7] P1
- [ ] **B19.17** CI blocks merges on any failure. P0

13. Build checklist — demo, pitch and video · S9 · hours 20–24

- [ ] **B20.01** `el demo-reset`: clean the demo series, generate v1 and v2 from a seed, ingest, approve, run, and leave the findings in review, ready for the live demo. [AC-1] P0
- [ ] **B20.02** Two demo staff accounts (reviewer, publisher) with TOTP on two devices. Credentials kept only in a password manager. [AC-1] P0
- [ ] **B20.03** Live demo script, 5 minutes at most, following US-D1. [C6] P0
- [ ] **B20.04** Outline for the 5-minute technical talk. P0
- [ ] **B20.05** Judge Q&A sheet: blockchain limits, neutrality, privacy, real data, relationship with ECI, false positives. P0
- [ ] **B20.06** 45–90 second promo video script and shot list: the problem, team-building, the demo, and how AI was used to make the video. [C6] P0
- [ ] **B20.07** Adoption slide (first 100, then 1,000 users) with no invented traction. P1
- [ ] **B20.08** Rehearsal on the live deployment. A recording is a backup only. P0

14. Traceability: every requirement → checklist items

Functional requirements

Requirement	Items
FR-ING-1	B01.01, B03.02
FR-ING-2	B03.01
FR-ING-3	B03.03

Requirement	Items
FR-ING-4	B03.05
FR-ING-5	B03.04
FR-ING-6	B01.05, B03.06
FR-ING-7	B03.06
FR-ING-8	B03.08
FR-ING-9	B03.07
FR-AUD-1	B02.01–B02.05
FR-AUD-2	B02.03, B04.01
FR-AUD-3	B04.04, B04.05
FR-AUD-4	B04.03
FR-AUD-5	B04.06, B04.07, B05.03
FR-AUD-6	B02.06, B04.09
FR-AUD-7	B02.04, B04.10, B09.07
FR-AUD-8	B04.11
FR-AUD-9	B04.08
FR-EXP-1	B05.01, B05.05
FR-EXP-2	B05.02
FR-EXP-3	B05.06, B05.07
FR-EXP-4	B05.04
FR-PUB-1	B09.01, B09.02
FR-PUB-2	B04.02, B09.04
FR-PUB-3	B09.05, B09.06
FR-PUB-4	B09.07, B15.12
FR-PUB-5	B08.04, B10.01, B10.02
FR-PUB-6	B09.03, B09.08
FR-PUB-7	B09.06, B09.12, B11.06
FR-PUB-8	B07.12, B09.09
FR-PUB-9	B09.04, B16.02
FR-PUB-10	B09.10
FR-CLM-1	B11.01
FR-CLM-2	B11.07
FR-CLM-3	B11.02, B11.04
FR-CLM-4	B11.03
FR-CLM-5	B07.05, B11.05, B11.06, B18.06
FR-AST-1	B09.10, B12.01, B13.04
FR-AST-2	B05.01, B12.02
FR-AST-3	B12.03

Requirement	Items
FR-AST-4	B12.04
FR-INT-1	B01.03, B01.04, B01.05
FR-INT-2	B01.06, B08.06
FR-INT-3	B07.10, B08.01, B08.02, B08.03, B18.07
FR-INT-4	B08.11, B08.12, B10.06
FR-INT-5	B08.07, B08.13, B10.01, B10.02, B10.03, B10.07
FR-INT-6	B10.05
FR-INT-7	B01.07
FR-QR-1	B13.03
FR-QR-2	B13.02, B13.05
FR-QR-3	B13.06
FR-QR-4	B02.05, B13.01, B13.03
FR-QR-5	B13.07
FR-ACC-1	B07.07, B14.01, B14.02
FR-ACC-2	B14.03, B14.04
FR-ACC-3	B14.06, B16.08
FR-ACC-4	B06.12, B07.03, B14.07
FR-ACC-5	B07.02, B14.07, B14.08
FR-ACC-6	B14.09
FR-GOV-1	B15.01–B15.05, B15.08, B15.09
FR-GOV-2	B06.09, B15.06
FR-GOV-3	B06.07, B15.08
FR-GOV-4	B09.08, B15.07
FR-GOV-5	B15.10
FR-GOV-6	B07.11, B15.11

Non-functional requirements

Requirement	Items
NFR-1 Privacy	B04.07, B16.01, B16.04, B16.05
NFR-2 Security	B00.01, B00.05, B17.01–B17.07
NFR-3 Neutrality	B03.10, B04.08, B05.04, B15.12
NFR-4 Reproducibility	B02.06, B04.09, B18.01
NFR-5 Performance	B04.12, B09.15
NFR-6 Availability	B09.13, B18.09
NFR-7 Accessibility	B09.04, B09.14, B19.16
NFR-8 Localisation	B05.01, B05.08
NFR-9 Low bandwidth	B09.15, B13.03
NFR-10 Cost	B18.15

Requirement	Items
NFR-11 Observability	B07.01, B07.13, B18.09, B18.12
NFR-12 Maintainability	B00.02, B00.03, B00.04, B00.06, B01.02, B18.01
NFR-13 Legal posture	B09.01, B09.11

Acceptance criteria

AC-1 → B19.01, B20.01 · AC-2 → B19.02 · AC-3 → B16.04, B19.03 · AC-4 → B06.15, B19.04 · AC-5 → B06.15, B19.05 · AC-6 → B10.05, B19.06 · AC-7 → B01.07, B19.07 · AC-8 → B04.10, B19.08 · AC-9 → B05.02, B19.09 · AC-10 → B05.04, B19.10 · AC-11 → B13.05, B19.11 · AC-12 → B11.08, B19.12

User stories

US-C1 → B09.04 · US-C2 → B05.01, B05.02, B09.06 · US-C3 → B13.03, B13.05 · US-C4 → B09.10, B12.01 · US-C5 → B11.01–B11.04 · US-C6 → B14.03–B14.05 · US-C7 → B12.03 · US-J1 → B09.09 · US-J2 → B10.01–B10.03 · US-J3 → B09.07 · US-J4 → B09.08 · US-S1 → B15.02 · US-S2 → B15.03 · US-S3 → B15.04 · US-S4 → B15.05, B15.06 · US-S5 → B15.05, B15.07 · US-S6 → B15.08 · US-S7 → B15.09 · US-D1 → B10.05, B19.01, B20.01

Threat controls

T01 → B06.10, B07.03 · T02 → B14.08, B14.10, B15.09, B17.11 · T03 → B03.03, B09.09, B19.14 · T04 → B06.08 · T05 → B06.10, B19.13 · T06 → B17.01, B17.02 · T07 → B17.03 · T08 → B03.08 · T09 → B07.04, B14.01 · T10 → B07.04, B11.05 · T11 → B16.02, B16.03 · T12 → B16.01, B16.02 · T13 → B08.01, §4.1 · T14 → B03.01, B09.03 · T15 → B05.04, B05.07 · T16 → B06.09, B08.06, B08.09 · T17 → B08.09, B08.10, B17.10 · T18 → B18.08 · T19 → B09.13, B17.07 · T20 → B04.08, B09.05, B15.12 · T21 → B18.08 · T22 → B17.05, B17.06 · T23 → B00.08, B17.09 · T24 → B09.06 · T25 → B09.01

---

15. Still open before or at hour 0

Decision	Needed by	Blocks
D2 domain and D3 Cloudflare	Hour 17 (deploy)	B18.04, B17.07
D4 third language	Hour 3 (templates)	B05.01, B09.01
D10 VPS size	Hour 17	Memory limits in §2
D6 LLM on or off	Hour 12	B05.06, B05.07, B11.07
New repo link	Hour 0	Everything